

SOC NEDİR, NE İŞE YARAR?

SOC; siber güvenlik uzmanlarından oluşan, siber güvenlik olaylarını önlemek, tespit etmek, analiz etmek, cevap vermek ve raporlamak için organize edilmiş bir ekip. SOC'nin işi bir kuruluşun tamamı için değil, "constituency" denen sınırlı bir küme (kullanıcılar, siteler, IT/OT varlıkları, veri, ağlar) için hizmet vermek.

Bir ekibin SOC sayılması için üç şartı karşılaması gerekiyor, kurum içindekilerin şüpheli olayları bildirebileceği bir yol sağlamak, olay müdahalesine yardımcı olmak, ve olayla ilgili bilgiyi ilgili taraflara yaymak.

SOC; NOC'tan (ağ operasyonu, saldırı değil işletim odaklı), CISO/CIO'dan (SOC gerçek zamanlı operasyonel, onlar politika/risk odaklı), ve kolluk kuvvetlerinden (SOC genelde hukuki soruşturma yetkisine sahip değil) ayrı tutuluyor.

Örnek:

SOC'nin misyonu bir sağlık sistemine benzetiliyor, aile hekimleri hastalığı önlemeye ve erken tespit etmeye çalışır (SOC'un rutin izleme ve tespiti gibi), acil servisler beklenmedik durumlar için var (olay müdahalesi gibi), ve uzmanlar gerektiğinde çağrılır (forensics, malware analizi gibi derinlemesine uzmanlık gerektiren işler).

Neden bir analist için önemli?

SOC'nin sınırlarını bilmek, hangi işin bana ait olduğunu hangi işin başka bir ekibe (NOC, hukuk, CISO) gitmesi gerektiğini anlamamızı sağlıyor. Case 2'de app-db01'e sızrayan saldırıyı incelerken, "bu benim yetkim dahilinde mi" sorusunu hiç düşünmemiştim, gerçek bir SOC'de bu sınırlar net çizilmiş oluyor.

SOC KATMANLARI

Çoğu köklü SOC, işi seviyelere (tier) böler. L1 analistler gelen olay/alarm akışını karşılar, hızlı triyaj yapar. L2/L3 ise daha derin analiz, araştırma, gerekirse adli inceleme yapar. Ama katmansız (tierless) çalışan SOC'ler de vardır. Bunlar seviyeye göre değil uzmanlığa ve fonksiyona göre ekipler kurar. Hangi modelin seçileceği kuruma bağlıdır.

** Katmanlı bir yapıda önemli bir tavsiye, L1 analistlerin işinin "düşük değerli" görülmemesi, çünkü SOC'nin ilk ve en kritik filtresi orası.

Örnek:

Bir kuruluştaki günde milyonlarca olay (event) üretiliyor, bunların çok küçük bir kısmı gerçek bir alarm haline geliyor, alarmların da çok küçük bir kısmı gerçek bir olaya (incident) dönüşüyor. L1'in görevi bu hunideki ilk elemeyi hızlıca yapmak, her şeyi kendisi çözmeye çalışmak değil.

Neden bir analist için önemli?

Rollerin nereye oturtulacağını bilmek için önemli. Bir L1 olarak asıl görev her alarmı sonuna kadar çözmek değil, hızlı ve doğru şekilde "bu gerçek mi, kime gitmeli" kararını verebilmek.

Event, Alert, Triage: Alarmin Yaşam Döngüsü

Event (olay), sistemde/ağda gözlemlenebilir herhangi bir şey, iyi ya da kötü olduğunu göstermez, sadece "bir şey oldu" demektir (örnek: bir kullanıcının dosya paylaşımına bağlanması).

Alert (uyarı/alarm), bir event'in ya da event serisinin potansiyel bir saldırı olabileceği ima edilerek üretilen teknik bir bildirim. Alarmlar iki şekilde üretilir, imza tabanlı (bilinen kötü davranışı, örneğin bir IOC eşleşmesini tanıma) ya da anomali tabanlı (normal davranışı tanımlayıp sapmaları yakalama). Triage ise gelen event ve diğer taleplerin sıralanması, kategorilendirilmesi ve önceliklendirilmesi süreci olarak tanımlanıyor.

Bir alarmin gelmesi tek başına kötü bir şey olduğu anlamına gelmiyor, sadece önceden tanımlanmış bir kriterin karşılandığı anlamına geliyor, gerçek anlamı çıkarmak insan analizi gerektiriyor.

Örnek:

Pearl Harbor saldırısından önce radarda büyük bir sinyal görülmüş ve bu, dost B-17 uçakları sanılmıştı, çünkü operatörlerin bağlamı (context) yoktu. Aynı şey SOC alarmları için de geçerli, bağlam olmadan tek bir alarm neredeyse hiçbir şey ifade etmiyor, ne kadar yüksek önem dereceli görünse bile.

Neden bir analist için önemli?

Bir alarmı görüp hemen panik yapmak ya da tam tersi görmezden gelmek yerine, "bu alarmı doğrulayacak başka hangi veri var" diye sormayı öğretiyor. Case 2'de zaten "bu bir saldırı" bilgisiyle başlamıştım, oysa gerçek bir SOC'de önce bunun gerçek mi yanlış pozitif mi olduğuna ben karar vermek zorunda kalacağım.

Ground Truth ve Otomasyon

Analistler ilk göstergelerden (yüksek öncelikli bir alarm gibi) başlayıp, otomasyon, standart süreç ve kendi deneyimlerini birleştirerek olayın "ground truth" yani gerçek/kesin halini ortaya çıkarmaya çalışıyor. Otomasyon (filtreleme, tekilleştirme, zenginleştirme, CTI ile birleştirme) triyaj sürecini büyük ölçüde hızlandırıyor, küçük bir analist grubunun milyonlarca event'ten türeyen alarmları yönetebilmesini sağlıyor. Fakat otomasyon büyük ölçüde yardımcı olsa da ileri düzey insan analistlerin muhakemesinin yerini tam olarak alamaz.

Örnek:

Bir alarm eskalasyona uğradıktan sonra, olayın kapsamını ve ciddiyetini belirlemek için gereken tüm

veriyi toplamak ve incelemek günler hatta haftalar sürebiliyor. Bir tek event bir olayı (incident) başlatabilir, ama her incident için milyonlarca event zararsız çıkıyor.

Neden bir analist için önemli?

Otomasyona güvenmek verimlilik için şart ama körü körüne güvenmek riskli, çünkü pozitif bir gösterge bazen yanlış çıkabiliyor. Bu yüzden yanıt (response) otomatikleştirilirken bile hız kazancı ile yanlış aksiyon riski arasında bir denge kurulması gerekiyor.

Yanlış Pozitif / Gerçek Pozitif / Alarm Yorgunluğu

Gerçek pozitif (true positive), alarmin gerçekten bir tehdide işaret ettiği durum.

Yanlış pozitif (false positive), alarmin tetiklendiği ama aslında zararsız bir aktiviteye ait olduğu durum.

Alarm yorgunluğu (alert fatigue), çok fazla yanlış pozitifin analisti köreltmesi, gerçek bir alarmin gürültünün içinde kaybolabilmesi durumu, SOC'lerin en bilinen hastalıklarından biri.

Örnek:

Çok geniş tanımlanmış bir tespit kuralı her gün yüzlerce zararsız bağlantıyı "şüpheli" diye işaretleyebilir, analist bir süre sonra bu kategoriyi otomatik olarak görmezden gelmeye başlar, tam o sırada gerçek bir tehdit aynı kategoride gelirse fark edilmeyebilir.

Neden bir analist için önemli?

Bir analistin en değerli becerilerinden biri gürültüyü elemek, hangi alarmin gerçekten dikkat gerektirdiğine hızlı ve doğru karar verebilmek. Bu teknik bilgiden çok deneyim ve iyi kalibre edilmiş şüphecilik gerektiriyor.

Temel SOC İş Akışı

Kuruluş varlıklarından gelen güvenlikle ilgili event'ler, kuruluş üyelerinden gelen bilgiler, ve siber tehdit istihbaratı (CTI) SOC'ye giriyor. Bunlar hem insan hem makine tarafından filtreleniyor ve değerlendiriliyor, amaç bir yanıt aksiyonu almak ya da "aksiyon gerekmiyor" kararına varmak. Süreç boyunca SOC, sistem yöneticileri ve servis sahipleriyle koordineli çalışıyor, böylece alınan aksiyonlar iş bağlamına uygun oluyor.

Örnek:

Kitap bunu bir OODA döngüsüne (observe, orient, decide, act, yani gözlemle, konumlan, karar ver, aksiyon al) bağlıyor, aslında bir savaş pilotunun karar döngüsünden uyarlanmış bir kavram. Analist sürekli gözlem yapıyor, önceki bilgiyle birleştiriyor, karar veriyor, aksiyon alıyor, ve tekrar başa dönüyor.

Neden bir analist için önemli?

Bu döngü, dakikalar içinde (bir alarmı değerlendirirken) ya da aylar içinde (SOC'nin araç setini geliştirirken) aynı şekilde işliyor. Bir analistin kendi işini bu döngü içinde görmek, "şu an hangi aşamadayım" diye kendisini konumlandırmasını kolaylaştırıyor.

TLP (Traffic Light Protocol): FIRST Standardı 2.0

TLP, bir bilginin kiminle paylaşılabilceğini gösteren dört etiketli bir sistem:

- **RED:** Sadece o an bilgiyi alanlarla sınırlı, başkasına gitmez.
- **AMBER:** Kuruluş ve müşterileriyle, bilmesi gerekenlerle sınırlı; **AMBER+STRICT** sadece kuruluşla sınırlar.
- **GREEN:** Kendi topluluğu içinde paylaşılabilir, herkese açık değil.
- **CLEAR:** Sınırsız, dünyayla paylaşılabilir.

Resmi bir gizlilik sınıflandırması değil, sadece paylaşım sınırını gösteriyor.

Örnek:

E-posta ve belgelerde etiket bilginin hemen önüne, konu satırına ya da her sayfanın üst/alt bilgisine konuyor. Alıcı bilgiyi geldiği etiketten daha geniş paylaşmak isterse kaynaktan izin almalı.

Neden bir analist için önemli?

Bir raporu ya da bulguyu doğru TLP etiketiyle işaretlemek, analistin işinin bir parçası, çünkü yanlış etiketlenmiş bir belge hassas bilgiyi yanlış kişilere ulaştırabilir. Aynı bulgu bazen sadece kurum içinde kalmalı, bazen sektörle paylaşılabilir, bazen tamamen halka açık olabilir, bunu ayırt etmek analistin sorumluluğunda. TLP olmadan her paylaşım kararı kişisel takdire kalır, standart bir etiket sistemi bu kararı tutarlı ve denetlenebilir hale getiriyor.

IcedID Macro Ends in Nokoyawa Ransomware

1)Zincir

1. Phishing mail ile makrolu bir excel eki geliyor.
2. Kullanıcı gömülü bir resme tıklayınca makro çalışıyor.
3. Makro, IcedID DLL'ini indirip diske yazıyor.
4. Yeniden adlandırılmış bir rundll32 ile DLL çalıştırılıyor.
5. C2'ye bağlanıyor (kicknocisd[.]com).
6. Yaklaşık 2 dk sonra otomatik discovery (whoami, systeminfo, net, nltest tarzı araçlarla).
7. Aynı sırada scheduled task ile kalıcılık kuruluyor.
8. Yaklaşık 2 saat sonra Cobalt Strike beacon'ları yükleniyor.
9. Dakikalar içinde SYSTEM'e yükselme + LSASS dump.
10. WMI ile Domain Controller'a lateral movement.
11. Port 1433 (MSSQL) taraması, şifre dosyaları için paylaşım gezintisi.
12. RDP, SMB, WinRM, PsExec (yeniden adlandırılmış) ile daha fazla lateral movement.
13. AdFind + 7-Zip ile AD verisi arşivleniyor.
14. BackConnect VNC ile elle klavye erişimi.
15. Şifre dosyaları muhtemelen C2 kanalı üzerinden sızdırılmış.
16. WMI + PsExec ile domain geneline Nokoyawa ransomware dağıtımı.

MITRE ATT&CK

Teknik Adı	ID	Gözlemlenen Davranış
Phishing: Spearphishing Attachment	T1566.001	Makrolu Excel eki phishing mail ile geldi
User Execution: Malicious File	T1204.002	Kullanıcı gömülü resme tıklayıp makroyu tetikledi
Ingress Tool Transfer	T1105	Makro, IcedID DLL'ini indirdi
System Binary Proxy Execution: Rundll32	T1218.011	Yeniden adlandırılmış rundll32 ile DLL çalıştırıldı
Masquerading: Rename System Utilities	T1036.003	rundll32 ve PsExec yeniden adlandırıldı
Application Layer Protocol: Web Protocols	T1071.001	IcedID ve Cobalt Strike C2'si HTTP/HTTPS üzerinden
Account Discovery	T1087.x	Otomatik discovery ile yerel/domain hesap bilgisi toplandı

Scheduled Task/Job: Scheduled Task	T1053.005	Beachhead'de kalıcılık kuruldu
OS Credential Dumping: LSASS Memory	T1003.001	SYSTEM yetkisiyle LSASS dump edildi
Windows Management Instrumentation	T1047	WMI ile DC'ye lateral movement ve ransomware dağıtımı
Remote Services: RDP / SMB / WinRM	T1021.001/002/006	Çoklu lateral movement yöntemleri kullanıldı
Unsecured Credentials: Credentials In Files	T1552.001	Paylaşımlarda şifre dosyaları arandı
Archive Collected Data: Archive via Utility	T1560.001	AdFind verisi 7-Zip ile arşivlendi
Remote Access Software	T1219	BackConnect VNC ile elle klavye erişimi
Exfiltration Over C2 Channel	T1041	Şifre dosyalarının C2 kanalından sızdırıldığı değerlendirildi
Data Encrypted for Impact	T1486	Nokoyawa ransomware ile domain şifrelendi
Valid Accounts	T1078	Lateral movement boyunca geçerli hesap kimlik bilgileri kullanıldı
Process Injection	T1055	Cobalt Strike beacon process injection kullandı

2)IOC Listesi

Tür	Değer
C2 (IcedID)	kicknocisd[.]com, 159.65.169.200
C2 (IcedID, sonraki)	curabiebarristie[.]com, guaracheza[.]pics, 198.244.180.66, 45.66.248.119
C2 (Cobalt Strike)	aicsoftware[.]com:757/8080, iconnectgs[.]com:8081, 5.8.18.242:443

BackConnect VNC	137.74.104.108:8080
Dosya	k.exe (ransomware), p.bat, mstdc.exe (yeniden adlandırılmış PsExec), l.dll (Cobalt Strike loader)
Fidye	Nokoyawa, \$200.000 talep, ödenmedi

3)Bu benim loglarımda nasıl görünürdü?

- Makro çalıştırma → Sysmon EventID 1
(EXCEL.EXE → rundll32.exe ; WINWORD.EXE → mshta.exe)
- Scheduled task → Windows Security 4698
- LSASS dump → Sysmon EventID 10 (GrantedAccess)
- RDP lateral movement → Windows Security 4624 (LogonType 10)
- PsExec → Windows Security 7045 (yeni servis kurulumu) + Sysmon EventID 1
- C2 beacon → firewall/proxy log'da düzenli aralıklı dış bağlantı

4)Tespit Düşüncesi

Bir .exe dosyasının iki farklı adı var: dosya sistemindeki görünen adı (yeniden adlandırılabilir) ve dosyanın derlenirken içine gömülen, meta veride duran gerçek adı (OriginalFileName). Dosyayı diskte yeniden adlandırmak bu gömülü meta veriyi değiştirmiyor, çünkü bilgi dosya sisteminde değil dosyanın kendi baytlarının içinde duruyor. PsExec'in gerçek dosyası, Microsoft tarafından derlenirken içine OriginalFileName: PSEXESVC.exe diye yazılmış. Saldırgan bu dosyayı mstdc.exe adıyla kaydetse bile, dosyanın içindeki bu meta veri hâlâ PSEXESVC.exe diyor, çünkü sadece dosya adı değişti, dosya yeniden derlenmedi. Sysmon'un process oluşturma kaydında (EventID 1) hem Image alanı (çalışan dosyanın görünen adı) hem OriginalFileName alanı (gömülü gerçek ad) ayrı ayrı loglanıyor.

Tespit kuralı fikri: dosya adı bilinen PsExec adlarından biri değilken OriginalFileName=PSEXESVC.exe eşleşirse alarm üret, çünkü meşru bir yazılımın kendini gizlemesi için hiçbir sebep yok.

5)Yönetici Özeti

Bir çalışan, sahte bir Excel dosyasındaki gömülü bir resme tıklayarak zararlı kodu tetikledi. Bu, önce gizli bir bağlantı kurulmasına, sonra saldırganların şirket ağında yayılıp yönetici yetkisi ele geçirmesine yol açtı. Altı gün sonra saldırganlar şirketin tüm bilgisayarlarını fidye yazılımıyla şifreledi ve 200.000 dolar fidye istedi; şirket ödemedi.